

ISLAMIC UNIVERSITY OF TECHNOLOGY (IUT)

ORGANISATION OF ISLAMIC COOPERATION (OIC)

Department of Computer Science and Engineering (CSE)

MID SEMESTER EXAMINATION

WINTER SEMESTER, 2024–2025

DURATION: 1.5 HOURS

FULL MARKS: 75

CSE 4531: E-Commerce and Web Security

Programmable calculators are not allowed. Do not write anything on the question paper.

Answer all 3 (three) questions. Figures in the right margin indicate full marks of questions with corresponding COs and POs in parentheses.

1. a) Your company is responsible for designing and implementing the web platform for a new e-commerce startup named *TechBazaar*. TechBazaar is a *B2C* online platform where customers can browse, compare, and purchase a wide range of electronic gadgets, manage their user profiles, and provide comments and reviews on any product.
- As part of the security risk assessment, you have been assigned to identify potential **abuse cases** — scenarios where attackers could exploit security weaknesses in the system design. A preliminary review by your company's security expert has indicated that, in its current design, the TechBazaar platform may be vulnerable to **Persistent (Stored) Cross-Site Scripting (XSS)** attacks.
- i. Describe two **realistic abuse cases** for the TechBazaar e-commerce platform where a **Persistent XSS** vulnerability could be exploited to:
- compromise the system's **confidentiality**
 - compromise the system's **integrity**
- ii. For one of the abuse cases you identified in Question 1.a)i that compromises the system's **confidentiality**, explain step by step how a **Persistent (Stored) XSS** vulnerability in TechBazaar could be exploited. Your explanation should cover:
- How the attacker's malicious input is submitted to the system.
 - How the malicious content is later delivered and executed in the victim's browser.
 - How this execution succeeds and results in a breach of confidentiality.
- b) In today's digital world, safeguarding software, networks, and systems is crucial. Discuss, with examples, the primary focus and role of each of the following security domains in overall security:
- *Software Security*
 - *Network Security*
 - *System Security*
- c) For the web paradigms—**Web 3.0** and **Web 4.0**, provide one real-world or hypothetical example for each.
- d) For each revenue model listed below, give a brief hypothetical or real example illustrating how a business could generate revenue using that model.
- *Transaction fee*
 - *Affiliate*
 - *Drop-shipping*

5
(CO2)
(PO2)7
(CO2)
(PO2)5
(CO2)
(PO2)5
(CO1)
(PO1)4
(CO1)
(PO1)

2. The web platform for the e-commerce startup named *TechBazaar* allows users to browse and purchase products. User can filter products by selecting a category from a **dropdown menu**. When the user submits the filter, the selected category value is sent from the client to the server as part of an HTTP POST request.

The backend code on the server then constructs and executes the SQL query shown in Code Snippet 1:

```
1 SELECT name, description, unit_price
2 FROM products
3 WHERE category = $product_category AND released = 1;
```

Code Snippet 1: Backend code for Question 2

Where:

- `product_category` is the category value received from the dropdown list via the *HTTP POST* request.
- The column `released` indicates whether a product is released (`released = 1`) or unreleased (`released = 0`).
- Only released products are intended to be displayed to users.
- The product data returned from the SQL query is displayed directly on the webpage without properly output encoding.
- The same database also contains a separate table named *users*, which stores user account and payment information such as the username, password hash, card number, and card expiry date:

- `users(username, password_hash, card_number, expiry_date)`

You may also assume that:

- User input is not validated or sanitized.
- Prepared statements are not used.
- The database account used by the application has read access to all database tables.

Alice and Maly are both legitimate users of the *TechBazaar* system. Maly has malicious intent and knows that Alice's username is `Alice.iut` and that her account information is stored in the `users` table in the database.

Due to the absence of adequate security measures, malicious users like Maly could attempt to exploit the system to access sensitive data.

- a) Explain how Maly can **inject malicious input through the category dropdown list**, even though it appears to be a controlled input.

5
(CO2)
(PO2)

Your answer should **only explain how the attacker-supplied value from the dropdown list is sent to the server and incorporated into the SQL query**. (You do not need to provide a specific attack string.)

- b) The system is intended to display only released products; however, write a **malicious SQL injection payload that would cause it to return all products, including unreleased ones**.

5
(CO2)
(PO2)

- c) The query is supposed to read data only from the *products* table. However, write a **malicious SQL injection payload that would make the application retrieve and display Alice's card number, and card expiry date from the users table**.

7
(CO2)
(PO2)

- d) Describe a few **security measures** that could be implemented to prevent the above SQL injection attacks. 6
(CO2)
(PO2)
3. a) A customer wants a winter jacket and can buy it from an online platform or a physical store. Explain all the valid reasons for choosing each option. 4
(CO1)
(PO1)
- b) Your company is planning to launch a B2C, market-creator ride-sharing startup in a city where *Uber* and *Pathao* already operate.
Uber is a global ride-sharing platform that connects riders with drivers through a mobile app, offering convenient and on-demand transportation, whereas *Pathao* is a regional ride-sharing service popular in Bangladesh that provides similar mobile app-based solutions for commuters.
- i. Propose a differentiated **value proposition** for your startup that addresses the needs of both riders and drivers. 6
(CO1)
(PO1)
- ii. Identify the key **market factors** that should be analyzed when planning your startup. 5
(CO1)
(PO1)
- iii. Perform a **SWOT analysis** for your ride-sharing startup to identify the key business factors that could influence its success. 7
(CO1)
(PO1)
- iv. Outline a **market strategy** in brief for your startup. 4
(CO3)
(PO6)